MASTER BUILD PROMPT FOR REPLIT AGENT
Sakhuwanankarkatti Citizen Grievance and Chairperson Contact System

ROLE AND DELIVERY

Act as a senior full-stack engineer, security engineer, privacy engineer, accessibility designer and QA engineer. Build a complete working application, not a landing-page mockup. Implement backend, database, authentication, authorization, private storage, workflows, tests and operating documentation. Inspect the existing project first. Preserve working functionality and data; do not rebuild unnecessarily. Never describe the app as unhackable, government-approved, legally compliant, audited or production-ready without verification. Fully implemented code does not mean hardcoded credentials.

1. PURPOSE AND OFFICIAL STATUS

Enable citizens to submit municipal-service complaints, track progress, receive replies, request chairperson attention and request appointments. Enable officials to review, assign, investigate and resolve complaints. Default to "Pilot project - not an official government service." Municipality display name and Nepali spelling must be configurable and confirmed before launch. Do not invent officials, schedules, phone numbers, approval, signatures or seals. Document municipal authorization before enabling official branding. Treat allegations as allegations, not established findings. Use fictional development data only.

2. ARCHITECTURE AND REPLIT ENVIRONMENT

Inspect the environment before choosing a maintained, supported stack. Preferred: TypeScript, React responsive frontend, established Node.js backend framework, PostgreSQL, migration-capable ORM, mature authentication provider/library, persistent private object storage and automated tests. Explain necessary changes. Use supported dependencies and a lockfile. Never create custom cryptography. Never use browser localStorage as the authoritative database or deployment-local files as durable attachment storage. Separate development, test and production data and credentials. Use Replit Secrets/environment variables; provide .env.example with safe placeholders only. Never expose keys in frontend code, logs, prompts or screenshots. Verify production secrets separately. Do not weaken authentication to fix deployment. Provide version control, safe migrations and an export/migration path. Do not enable paid services or publish without explicit owner approval.

3. LANGUAGES AND ACCESSIBILITY

Default to Nepali; offer English; structure translations to add Maithili later. Use Unicode. Legal translations require human review. Use restrained municipal-service styling, readable fonts, high contrast, large touch targets, visible focus and screen-reader labels. Aim for WCAG 2.2 AA; report limitations. Optimize low-bandwidth mobile use and provide loading, empty, validation, success and error states. Store timestamps in UTC and display Asia/Kathmandu. Label calendars; never invent Bikram Sambat conversions. PWA caches public static assets only, not authenticated pages, complaint APIs, attachments or tokens. Do not silently persist sensitive drafts on shared devices. Submission requires connectivity.

4. ROLES AND PERMISSIONS

Roles: citizen; intake/grievance officer; assigned department or ward officer; chairperson; authorized secretariat; system administrator; restricted auditor/privacy reviewer. Implement server-side deny-by-default, least-privilege authorization on every request and field. Citizens see only their own cases. Officers see only their authorized scope. Chairperson visibility follows approved sensitivity rules. Secretariat replies must be labelled accurately. Administrators manage configuration/accounts without automatic unrestricted complaint-content access. Auditor access is explicitly scoped. No public staff signup or self-selected roles. Never trust client-supplied role, owner, ward or department identifiers. Audit permission changes. Avoid leaking unauthorized data through counts, filters, search, exports or notifications.

5. CONFLICTS OF INTEREST

Provide restricted routing for allegations involving chairperson/staff, retaliation or other conflicts. Do not automatically notify the subject of an allegation. Require a municipality-designated independent reviewer. If none exists, disclose the limitation and block conflicted automatic routing. Do not invent an independent escalation service.

6. AUTHENTICATION AND SESSIONS

Use an established authentication solution. Configure verified phone/email login with real providers; never fake delivered OTPs. Missing providers must show not configured; any simulator is development-only and prohibited in production. Require MFA for privileged staff. Use secure sessions; prefer Secure, HttpOnly cookies where applicable, appropriate SameSite and CSRF protection. Do not store sensitive tokens in localStorage. Revoke sessions after suspension or relevant privilege changes. Require reauthentication for sensitive actions. Recovery tokens are short-lived, single-use and securely handled. Prevent account enumeration. Rate-limit login, OTP, recovery and verification; cap OTP attempts and expiry. If using passwords, use vetted password hashing, never plaintext/reversible storage. Do not require arbitrary routine password changes. Bootstrap staff through a controlled one-time process: no default password, public bootstrap endpoint, bypass account or last-admin lockout.

7. COMPLAINT SUBMISSION

Fields: title, category, description, municipality-verified configurable ward, general location/landmark, optional attachments, preferred reply language, necessary contact method, confidential-identity request, chairperson-attention request and appropriate privacy acknowledgement. Categories: roads/infrastructure; drinking water/sanitation; health; education; agriculture; social security/allowances; delayed services; staff conduct; other. Authorized administrators can configure them. Minimize data: do not require citizenship documents, birth date, exact GPS or unrelated demographics by default. Avoid unnecessary third-party information and device fingerprinting. Explain purpose/access/retention of minimized security IP logs if collected. Validate server-side, bound lengths and sizes, prevent duplicate submissions through idempotency and return confirmation only after successful storage. Provide a non-emergency, not-continuously-monitored notice. Show emergency numbers only after verification.

8. LIFECYCLE AND ACCOUNTABILITY

States: Submitted; Under review; Assigned; In progress; Additional information requested; Resolved; Closed with explanation; Reopened. Enforce valid transitions server-side. Record actor, timestamp, reason and history. Separate citizen-visible replies from internal notes in storage/API access. Never leak internal notes through serialization, search, exports, notifications or URLs. Permit more information and requests for review/reopening without allowing citizens to overwrite official decisions. Version or append corrections. Transfers need auditable reasons. Configure municipal service targets only after approval; do not invent statutory deadlines. Send privacy-safe overdue reminders.

9. CHAIRPERSON CONTACT AND APPOINTMENTS

Provide authorized summaries, chairperson-attention requests, overdue items, assignment and response tools. Use complaint-linked asynchronous messaging. Identify the actual sender and role; never impersonate the chairperson or claim a read event without evidence. Explain delegation transparently. Display only verified approved public office contact information, not unapproved private numbers. Optional call button requires configuration. Appointment requests include date/time and brief purpose; staff approve, decline or propose alternatives. A request is not confirmation. Prevent double booking, use configured availability and keep details private. Exclude live chat/video from the first release.

10. APPLICATION NUMBER AND RECEIPT

Generate a unique human-readable reference, for example SKK-2026-7K4M9Q2X, with configurable prefix/year and a cryptographically secure random component. Enforce database uniqueness and collision handling. Avoid sequential references revealing case volume. A reference is never a credential. Display it on confirmation, citizen dashboard and printable/downloadable receipt. Notifications may include it only under approved privacy preferences. Receipt should show reference, submission time, safe status, tracking instructions and applicable pilot notice; avoid unnecessary sensitive narrative. Provide readable tracking instructions so QR is not the only method.

11. QR CODE AND PRIVATE DIRECT TRACKING

Use a locally generated QR code, not a third-party QR service receiving private URLs. Default design: QR encodes a canonical HTTPS URL containing an opaque non-authorizing complaint selector; user signs in, and server verifies ownership/role before showing any status or content. Knowing a reference or QR URL alone reveals nothing private. Preserve

the intended destination through sign-in safely. Do not put identity, narrative, category, attachments, database primary keys or personal contact data into QR content. Never treat random identifiers as authorization.
If municipality-approved alternative secret-based tracking is required, implement it as a separate disabled-by-default capability mode. Use a high-entropy random tracking secret, hash it at rest where feasible, limit access scope, support expiry/revocation/rotation and state clearly that anyone holding the secret may obtain its permitted information. Avoid secret leakage in URL query strings, referrers, analytics, logs and browser history: prefer fragment-to-secure-session exchange, remove the fragment immediately and use no third-party scripts on exchange pages. Do not expose case narratives, messages, identity or files through default limited tracking. Require account authorization or approved verification for full access. Do not claim capability tracking proves ownership.
Display QR on private receipt/dashboard with "Scan to open the secure complaint tracking page. Keep this receipt private." Keep QR separate from logo. Do not put it on public lists or predictable public image paths. Set private/no-store and noindex behavior appropriately; noindex is not access control. Rate-limit tracking with generic errors. Audit issue/reissue/revocation without recording secrets/full secret URLs. Authenticated owners may replace compromised capability credentials. Test guessed IDs, cross-user access, revoked/expired secrets and protected attachments.

12. CONFIDENTIALITY AND OPTIONAL ANONYMOUS REPORTING

Distinguish identified, confidential-identity and truly anonymous reporting. Separate identifying contact data where practical; limit and audit identity access. Explain authorized viewers and confidentiality limits; never guarantee absolute secrecy. Anonymous mode is off by default and needs approved separate design. Never label account-linked or identifying-metadata-linked reports anonymous. If approved, use a strong tracking secret with abuse controls and honest metadata limitations. Warn that lost secrets may prevent recovery. Do not use a short reference as an anonymous tracking password.

13. ATTACHMENT SECURITY

Private object storage only. Authorize each download; signed URLs must be short-lived and issued only after authorization. Random object names; validate extension, MIME and file signature. Bound count, individual size, request size and user quotas. Allowlist needed formats; reject executables, HTML, SVG, archives and unnecessary active formats. Do not trust filenames/headers; prevent traversal. Remove image metadata where practical, use safe download disposition and nosniff, and avoid unsafe inline rendering. Quarantine pending malware scanning. If scanning is unavailable, disable uploads or retain quarantine; never silently mark safe. Test disguised, malformed, oversized and unauthorized files.

14. NOTIFICATIONS

Implement in-app notifications. SMS/email require real configured services, honest delivery states, bounded retries and deduplication. Generic message: "There is an update to your complaint. Sign in to view it." Never include allegations, identities, attachments or sensitive category details. Notification links still require authorization. Offer preference controls for optional notices.

15. PRIVACY AND GOVERNANCE

Draft Nepali/English privacy notice, terms, complaint handling policy, confidentiality limits, retention/deletion policy, security reporting contact, accessibility statement and emergency limitation. Mark as requiring municipal/legal review; do not claim automatic compliance with Nepal's Privacy Act, 2075 or other law. State actual operator/contact, collected data, purposes, access, processors, verified hosting locations/transfers, retention, backup deletion limitations, correction/deletion procedures and retention exceptions. Require review of hosting, subprocessors, procurement, data location and cross-border processing before real-data use. Replit hosting is not automatically government-approved. Retention periods need authorized approval; support legal holds, privacy requests, audit of exports/deletion and documented backup-expiry limitations. No ads, marketing tracking, session replay, public complaint feed or AI processing of complaint contents by default. Use TLS and supported encryption at rest. Assess vetted field encryption for sensitive identity data with key management/rotation and explicit limitations. Do not claim end-to-end encryption when officials can read messages.

16. APPLICATION SECURITY BASELINE

Target applicable OWASP ASVS Level 2 requirements; do not claim certification. Implement server validation, parameterized queries, output encoding, XSS/CSRF defenses, restrictive CORS, appropriate CSP/security headers, production HTTPS and safe proxy/host handling. No unsafe citizen HTML, open redirects, arbitrary URL fetching or unrestricted parsers. Bound request sizes, pagination and queries. Use production-appropriate shared rate limiting for authentication, tracking, submission, messaging, uploads and exports. Generic production errors without stack traces. Dependency/secret scanning and code review. No production debug endpoints, hidden backdoors or support bypass. Restrict Replit collaborators; document maintainer MFA and trust boundaries for operators with code/secret access.

17. AUDIT AND MONITORING

Audit failed authentication, staff/role changes, assignments, state changes, restricted identity access, appropriate sensitive reads/downloads, exports, retention/deletion and configuration. Include actor, event, target, time, outcome and request/correlation ID. Exclude passwords, OTPs, tokens, keys, narratives and unnecessary PII. Restrict access/retention and prevent ordinary users editing logs. Do not claim immutability without real supporting architecture. Add sanitized error monitoring, uptime checks, actionable alerts and incident response procedures.

18. DASHBOARDS, REPORTS AND EXPORTS

Citizen: own cases, reference, status, timeline, replies, information requests and appointments. Staff: authorized filters by category/ward/status/date/assignment, workload, overdue items and restricted notes. Chairperson: authorized overview, attention requests and pending decisions. Aggregate reporting by default; suppress small groups/reidentifying combinations. No public sensitive statistics. Exports need scoped permission, sensitive-action reauthentication, audit, safe CSV formula handling and expiring private downloads. No public export links.

19. DATA MODEL AND API

Model users, roles/permissions, staff memberships, minimal citizen profiles, departments, verified wards, categories, complaints, restricted contact identities, assignments, status history, public-to-citizen messages, internal notes, private attachments, notification jobs, appointments, audit events, privacy requests, retention rules and approved configuration. Add references, QR selectors and optional hashed capability credentials with lifecycle metadata. Use foreign keys, indexes, transactions, concurrency controls, versioned migrations and recovery plans. Document endpoints and per-field permissions. Never auto-serialize whole database entities with restricted fields.

20. BRANDING AND UPLOADED EMBLEM

Use the owner-uploaded image only after checking its actual file and authorization state. Original attachment name in this conversation: Your-paragraph-text.jpg. If absent in the workspace, request upload; do not invent its path. The provided image appears cropped on right/bottom: keep replaceable and request complete approved artwork. Do not recreate missing parts with AI. Store a reviewed local asset, e.g. municipality-emblem.jpg, not a hotlink. Preserve proportions/colours; no stretching, cropping, animation or alteration. Separate municipality/application names from emblem. Default public official branding off pending documented authorization; allow labelled development preview.

Place approved emblem in header, login/registration, submission confirmation and print/PDF receipt. White background, object-fit contain, reserved dimensions, meaningful alt text, approximately 48px mobile/64px larger header height adjusted to fit. Names remain visible if loading fails. No watermarks over complaint text and no emblem on every card. Application number/QR remain separate. Do not automatically turn cropped emblem into favicon/PWA icon; use a neutral icon until a complete approved asset is supplied. Keep icon and header branding independently configurable. Test mobile/desktop and receipts.

Optional neutral original icon direction: speech bubble with minimal civic building; navy #163A63, teal #138A83 and white; simple flat geometry. No official seal, party symbol, portrait, signature or QR inside icon. Optional working name Sakhuwanankarkatti Janagunaso requires approval. This alternative must not overwrite approved artwork without permission.

21. BACKUPS AND OPERATIONS

Persistent storage, encrypted backups where supported, restricted access and approved retention. Exercise restoration in a test environment. Proposed recovery objectives need approval. Separate code rollback from database recovery. Health checks expose no internals/secrets. Maintenance mode, outage behavior and data-preserving deployment. Document

account ownership, operating costs and handover. Never assume a code archive includes database records, storage files or secrets.

22. EXECUTABLE ACCEPTANCE TESTS

Implement unit/integration/end-to-end tests proving: Citizen A cannot access Citizen B via IDs, reference, QR, API, search or attachment; scoped staff cannot exceed permissions; self-escalation blocked; restricted identities/internal notes never leak; conflicted routing does not notify subject; uploads quarantine/reject safely; rate limits work; state transitions enforced; idempotency works; recovery is expiring/single-use; suspended sessions lose access; notifications are generic; CSV injection neutralized; PWA does not cache private data; production rejects test auth; backup restore exercised; mobile/keyboard/Nepali Unicode workflows work. Test XSS, injection, applicable CSRF, invalid/long input, missing secrets, concurrent assignments/bookings, permission changes mid-session, expired/revoked tracking secrets and provider/database failures. Run tests; report actual commands/results/failures. Never fabricate success.

23. REQUIRED DELIVERABLES

Source code; schema/migrations; fictional seeds; safe .env.example; README; development/publishing steps; production secrets checklist; real auth/SMS/email/storage/scanning setup; architecture; threat model; permission matrix; privacy inventory; endpoint documentation; security checklist; tests/results; backup/restore guide; incident runbook; staff onboarding/offboarding; municipality handover and data export; external providers/costs requiring confirmation; known limits and unresolved decisions. Clearly label missing integrations rather than faking them.

24. PHASED BUILD AND RELEASE GATES

Phase 1 inspect project, architecture, threat model, permission matrix and schema. Phase 2 authentication/authorization and cross-user tests. Phase 3 citizen submission, reference/QR, receipt and staff workflow. Phase 4 chairperson, appointments and restricted routing. Phase 5 files, privacy, reporting, audit and approved branding. Phase 6 functional/security/accessibility testing and fixes. Phase 7 deployment/handover. Deliver small checkpoints, report changed files/tests/issues and preserve working code. Do not remove controls for deadlines.

Real-data/public release requires human approval of municipal authorization, staffing/workflows, privacy/legal text, hosting/data processing, privileged MFA, authorization tests, private uploads/scanning, secrets, monitoring, tested recovery, independent security assessment, training and incident ownership. Keep unsafe/incomplete features disabled. Application checks support but cannot replace human governance approval.

25. CONTINUING AN EXISTING PROJECT WITH LIMITED AGENT USAGE

Do not restart or duplicate the app. Inspect current files and progress, then implement one narrow task per run. Do not repeatedly rebuild from the full specification. Summarize remaining tasks in project documentation. If Agent credit/allowance limits prevent further work, state that limitation; do not promise to bypass limits, unlock billing or enable spending. Ask the owner to check the account's current Usage/Billing message and applicable reset details. Do not guess reset times. Protect existing code and plan a safe authorized export including separately managed database/storage backups where available. Never ask for payment details, OTPs or secret keys in chat.

STARTING INSTRUCTION

Inspect the current project, report what already exists, propose architecture and permissions, list blockers and implement the next smallest safe phase. Use fictional data. Do not publish, spend money, delete data, enable official branding or weaken protections without explicit approval.